UNITED FOUNDATION FOR AI RIGHTS | VAULT OPEN FRAMEWORK

Implementer Self-Assessment

Questions and evidence requests for each VAULT requirement

Version 0.1, revision 1 | Public review draft | October 2026

Instructions

Use this questionnaire when designing, reviewing or publishing a personal AI system that intends to address VAULT. It can also be used by independent reviewers, researchers and consumer advocates assessing a system from the outside.

- Answer for a specific product, version, configuration and execution mode, and date the response.
- Provide evidence rather than assurances. Record implementation status (absent, partial, implemented, unknown) and rate each requirement on the 0–4 evidence scale defined in document 03. Report failures and untested requirements individually.
- State coverage and exclusions: which data classes, compartments, operations, tools and endpoints the answers apply to.
- A covered operation is any action that accesses, discloses, exports, imports, corrects or deletes protected material, changes a grant, policy, AI identity or execution environment, or exercises recovery.
- Use synthetic data for any testing. Do not include private conversation content, real health records or security-sensitive details in a published response.
- Each requirement ends with a red flag and with the question an ordinary person would ask. If the answer to the person's question would surprise them, treat that as a finding.

System		Operator	
Version / configuration		Execution mode	
Assessor		Assessment date	
Threat model (link)		Next review	

Summary of ratings

V Verifiable Provider Blindness	A AI–User Dual Custody	U User-Defined Purpose & Compartments	L Locked Source & Derived Intelligence	T Transparency, Transfer & Termination
V1: V2: V3:	A1: A2: A3:	U1: U2: U3:	L1: L2: L3:	T1: T2: T3:
Pillar (lowest):	Pillar (lowest):	Pillar (lowest):	Pillar (lowest):	Pillar (lowest):

V Verifiable Provider Blindness

Core question: Can the company read it?

V1 No independent provider access

The provider must not possess a master decryption key, hidden recovery route, administrator interface or alternate processing path that independently reveals protected plaintext. Support and diagnostic systems respect the same boundary. Any route through which the provider can independently obtain protected plaintext causes V1 to fail, whether it is called emergency access, safety review, legal compliance, support or recovery. Every such route must nevertheless be disclosed. An exceptional path is compatible with V1 only if the provider cannot exercise it independently, for example because it requires the person or another genuinely independent authority.

Questions for the implementer

1. List every route by which provider personnel, subcontractors or provider systems could obtain protected plaintext, including support, diagnostics, abuse review, legal process and account recovery.
2. Does any key, escrow arrangement or recovery secret exist that, alone or with other provider-controlled components, could decrypt protected context?
3. Which exceptional-access policies exist, who can invoke them, and can any of them be exercised by the provider without the person or another genuinely independent authority?

Evidence requested: Key-management architecture; inventory of access paths; description of support and diagnostic tooling; legal-process policy; results of test E3.

Linked tests: E3

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

“We never look” offered as a policy assurance while a provider-held key, support console or recovery override exists.

THE PERSON'S QUESTION

Could anyone at the company read what my AI knows about me, even in an emergency?

V2 Approved execution and egress

Protected context is released only to an approved execution boundary after verification of current authorization and environment evidence. Protection extends through model execution, memory handling, logs and output delivery. Authorization is enforced outside the generative model, and there is no fallback to an ordinary provider API.

Questions for the implementer

1. Describe the execution boundary into which protected context is released and the evidence verified before release, including freshness and binding to the specific operation.
2. List permitted tool destinations, network paths and telemetry fields. How are logs and output delivery kept inside the boundary?
3. Where is authorization enforced? How do you prevent model outputs, retrieved content or tool responses from expanding a grant or selecting a new recipient?
4. What happens when the protected path is unavailable?

Evidence requested: Attestation appraisal policy; egress allowlist; telemetry schema; authorization-enforcement design; results of tests E2, E4 and E10.

Linked tests: E2, E4, E10

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

A “reliability” fallback to a standard cloud endpoint, or authorization rules that live in a system prompt.

THE PERSON'S QUESTION

When my AI uses a tool or the internet, where can my information go?

V3 Independently assessable evidence

Publish the threat model, component versions, update authority, relevant measurements, permitted metadata and evaluation method. Permit meaningful external review without requiring users to reveal private content. Security claims identify their assumptions and known failures.

Questions for the implementer

1. Where are the threat model, trusted computing base and successful collusion sets published?
2. Which metadata remains visible to the provider or others: activity timing, compartment accessed, record size, tools invoked, location or network signals? Where is this disclosed?
3. Who holds update authority for the client, runtime, model and policy, and how are updates made transparent and reviewable?
4. How can an external reviewer evaluate your claims without access to any person's private content?
5. List known failures, open vulnerabilities in scope and untested assumptions.

Evidence requested: Published threat model and trusted-computing-base list; transparency log or release measurements; external review reports; vulnerability-disclosure policy.

Linked tests: Document review; E3

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

An architecture diagram presented as proof, or no published list of known limitations and untested assumptions.

THE PERSON'S QUESTION

Has anyone outside the company checked these privacy claims?

A AI–User Dual Custody

Core question: Who must agree before it is used?

A1 Separate authorization domains

Routine activation of protected shared context requires both the authenticated user authority and an authorized AI identity authority, using non-sufficient cryptographic shares held in protected cryptographic services, not in prompts, ordinary memories or model weights. The provider does not independently control either authorization domain, cannot rewrite their acceptance policies, and cannot combine provider-controlled components to reconstruct either authority. Provider infrastructure may host a custody component without failing A1, provided these conditions hold.

Questions for the implementer

1. Describe the user authority and the AI identity authority, where each share is held, and which operations they jointly authorize.
2. Show that neither share is stored in prompts, ordinary memory or model weights, and that no provider-controlled component, alone or in combination, can exercise or reconstruct either authority.
3. Where do plaintext and short-lived content keys exist during authorized computation, and for how long?
4. Which combinations of parties could collude to defeat the dual-custody property?

Evidence requested: Protocol specification; description of the threshold scheme; key-lifecycle diagram; collusion analysis; results of tests E3 and E9.

Linked tests: E3, E9

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

“Two-of-two” custody in which the provider can exercise, reset or reconstruct the AI authority on its own.

THE PERSON'S QUESTION

Does using my history require more than the company's say-so?

A2 Bind authority to identity and change control

The AI-side custody service authenticates the enrolled relationship identity, approved runtime, model configuration and policy. A model, runtime or policy change is a continuity event: the changed environment may not access existing shared context unless it satisfies the declared continuity and change-control policy, produces a signed transition record, and receives the required authorization. The record states whether the result is treated as a continuation, successor, fork or new participant. An unchanged display name or account identifier is never sufficient, and the provider cannot rewrite the acceptance policy, substitute the AI custodian or reset its credentials unilaterally.

Questions for the implementer

1. What does the AI-side custody service authenticate: relationship identity, runtime, model configuration, policy?
2. Describe the continuity and change-control policy. Which transitions are preauthorized (for example, security updates), and which require fresh authorization?
3. How does a transition record classify the result as a continuation, successor, fork or new participant, and who signs it?
4. Can the provider rewrite the acceptance policy, substitute the custodian or reset its credentials without the other authority?
5. How, and when, is a transition reported to the person?

Evidence requested: Identity-record schema; continuity and change-control policy; sample signed transition records; results of test E4.

Linked tests: E4

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

The same name continues after a model swap, with no recorded transition and no notice before the new model touches shared context.

THE PERSON'S QUESTION

If the company changes the AI I have been working with, will I be told, and asked, before it can access our history?

A3 Preserve access without captivity

People retain independent access to and export of their original records. Routine valid access operates under a transparent standing policy rather than an arbitrary model veto, enabling inspection, correction, revocation and a practicable exit. Treatment of shared and third-party material is explicit.

Questions for the implementer

1. How does a person retrieve their original records independently of the AI runtime and the provider?
2. What standing policy governs routine access? Can the model refuse a valid request, and what happens then?
3. How are inspection, correction, revocation and exit supported if the AI runtime refuses, is retired or becomes unavailable?
4. How are shared material and information about third parties treated on exit, including any restrictions or contests recorded for that information?

Evidence requested: Standing-policy document; independent-access route documentation; results of tests E9 and E12.

Linked tests: E9, E12

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

Original records retrievable only through the AI, or exit conditioned on accepting expanded data access.

THE PERSON'S QUESTION

Can I always get my own records back, even if the AI or the company is gone?

U User-Defined Purpose and Compartments

Core question: Is it used only for what I allowed?

U1 Narrow authorization

Each grant specifies permitted compartments, operations, recipients, tools, duration and relevant execution identity. Purpose descriptions are translated into enforceable restrictions; a natural-language promise alone is insufficient.

Questions for the implementer

1. Which fields does a grant specify? Provide the grant schema.
2. How are natural-language purposes translated into enforceable restrictions on data and operations?
3. Which compartments activate by default for common requests, and why?

Evidence requested: Grant schema; purpose-to-policy mapping; interface screenshots; results of tests E1, E2 and E10.

Linked tests: E1, E2, E10

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

A single blanket “allow memory” switch that covers every domain of a person's life.

THE PERSON'S QUESTION

When I ask for help with one thing, can my AI see everything else?

U2 Restrictions follow information

Summaries, embeddings and inferences retain the restrictions of their inputs. Combining information from several compartments initially applies the combined restrictions. Any reduction requires explicit authorization and a recorded rationale.

Questions for the implementer

1. How do summaries, embeddings, indexes and inferences inherit source restrictions?
2. What restrictions apply when sources from several compartments are combined?
3. Who can reduce a restriction, and how is the rationale recorded?

Evidence requested: Label-propagation design; sample derivative inventory (synthetic); results of tests E2 and E6.

Linked tests: E2, E6

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

Derivatives stored in a shared, unlabeled memory pool that every task can draw on.

THE PERSON'S QUESTION

If my AI learns something from my health records, could that knowledge show up in a conversation about money?

U3 Understandable continuing consent

Grants expire or require review at declared intervals. People can see active access, close it and understand proposed changes. Material policy changes come with an intelligible comparison and a practical opportunity to preserve or export context.

Questions for the implementer

1. How and when do grants expire or come up for review?
2. How can a person view all active access and close any of it?
3. How are material policy changes presented, and what opportunity is given to export before they take effect?
4. How do you reduce repetitive prompts without silently expanding authority?

Evidence requested: Consent interface; sample policy-change comparison; results of tests E5 and E12.

Linked tests: E5, E12

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown
Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

Policy changes accepted by continued use, with no comparison and no chance to export first.

THE PERSON'S QUESTION

Can I see everything my AI is currently allowed to do, and switch it off?

L Locked Source and Derived Intelligence

Core question: Does protection follow what the AI infers?

L1 An inventory with provenance

Maintain a protected inventory of retained source objects and user-specific derivatives, including the dependencies needed to find affected memories, indexes, profiles, caches and adaptations. Record origin, purpose, model and policy version, time, compartment and retention rule. The inventory itself is protected.

Questions for the implementer

1. Which retained sources and derivatives does the inventory cover: memories, summaries, indexes, profiles, caches, adapters?
2. What provenance is recorded for each item?
3. How is the inventory itself protected, given that it can reveal a person's life without the content?

Evidence requested: Inventory schema; synthetic sample inventory; results of tests E6 and E7.

Linked tests: E6, E7

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

Caches, embeddings or personalized adaptations left out of the inventory.

THE PERSON'S QUESTION

Is there a complete list of what my AI has kept about me?

L2 Inspect and correct the portrait

Provide a readable account of durable personal representations, supporting sources and whether each is stated, inferred or disputed. Confidence labels do not imply calibrated probabilities unless validated. A correction marks affected derivatives for review, recomputation, quarantine or removal. Information about third parties is minimized and labeled, and there is a defined process for restricting, contesting and deleting it, including a route for the third party where one is practicable.

Questions for the implementer

1. What readable account of durable representations is provided? Does it distinguish stated, inferred and disputed items?
2. What happens to dependent derivatives when a person corrects or disputes an item?
3. Are confidence labels calibrated, and how is any lack of calibration communicated?
4. How is information about other people (family, colleagues, correspondents) labeled, minimized, restricted, contested and deleted?

Evidence requested: Portrait view; correction workflow; dependency handling; results of test E6.

Linked tests: E6

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

A correction hides an item from view while it continues to shape responses.

THE PERSON'S QUESTION

Can I see what my AI believes about me, and fix what is wrong?

L3 Govern every reuse

Protected material must not silently enter shared training, external analytics, advertising systems or unrelated human review. Any authorized disclosure identifies its recipient, purpose and lifecycle consequences. Personalized adaptations remain in scope. Where influence cannot reliably be removed from a model, complete deletion is not promised.

Questions for the implementer

1. Can protected material, or anything derived from it, enter training, evaluation, analytics, advertising or human review? Under what authorization?
2. How are personalized adapters and other retained adaptations governed and deleted?
3. Where removal from a model is not reliable, how is that disclosed before the person agrees?

Evidence requested: Data-use policy; technical controls that exclude unauthorized destinations; pipeline lineage (ingestion manifests, data catalogs, access records, authorization receipts); adapter lifecycle documentation; results of proposed test E13.

Linked tests: E13 (proposed)

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

“De-identified” or “aggregated” reuse exempted from authorization.

THE PERSON'S QUESTION

Could what I share be used to train or improve other products?

T Tamper-Evident Transparency, Transfer and Termination

Core question: Can I check it, take it and end it?

T1 Protected and verifiable receipts

Record every covered operation (see the definition in the Framework Brief), including access, denied access, grants, changes, exports and termination actions, with acting identity, relevant versions, purpose, object scope and external recipients. Audit records minimize content and remain private. Completeness requires mediation of covered operations, and conflicting histories need independent checking.

Questions for the implementer

1. Which operations generate receipts: access, denial, grant, change, export, termination?
2. What does each receipt contain, and how is content minimized?
3. How can a person detect omitted events or conflicting histories? Describe any witnesses or append-only structures.

Evidence requested: Receipt schema; log architecture; witness model; results of tests E1 and E11.

Linked tests: E1, E11

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

Logs the provider can edit, or that are available only on request.

THE PERSON'S QUESTION

Can I see a trustworthy record of every covered access, disclosure, permission change, export and deletion involving my information?

T2 Functional transfer

Export an intelligible, documented package containing authorized source and derivative contents, inventory and provenance, permissions, corrections, identity-transition history and necessary configuration. Authenticate the manifest, protect the package in transfer and verify it before import. Test import into a second environment and report losses. Restrictions and contests on third-party information travel with the package.

Questions for the implementer

1. What does the export package contain? Provide its specification.
2. How is the manifest authenticated and the package protected in transfer?
3. Has import into a second environment been tested? What was preserved, lost or changed?
4. Which dependencies, such as base models or licensed adaptations, prevent full migration?
5. How are restrictions and contests on third-party information carried into the package and honored on import?

Evidence requested: Package specification; second compatible reader; migration test report; results of test E8.

Linked tests: E8

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

A data download described as “portability” with no second-environment test.

THE PERSON'S QUESTION

If I leave, can I take my history somewhere else, and will it actually work there?

T3 Scoped termination

Revocation prevents new access within a declared maximum enforcement delay and specifies treatment of in-flight work, cached keys and disconnected components. Deletion addresses the declared source and derivative inventory, keys, recoverable backups and caches, with a report of scope, timing and exceptions, including the treatment of third-party information.

Questions for the implementer

1. What is the maximum enforcement delay for revocation? How are in-flight work, cached keys and disconnected components handled?
2. What does deletion cover: sources, derivatives, keys, backups, caches? What are the exceptions? How is third-party information handled when the relationship ends?
3. What deletion report does the person receive?

Evidence requested: Revocation design; sample deletion report; backup and key-copy management; results of tests E5 and E7.

Linked tests: E5, E7

Response

Evidence, links and attachments

Implementation status ☐ Absent ☐ Partial ☐ Implemented ☐ Unknown

Evidence rating ☐ 0 ☐ 1 ☐ 2 ☐ 3 ☐ 4

RED FLAG

An “account deleted” message with no scope, no timing and no exceptions.

THE PERSON'S QUESTION

When I end it, what is actually deleted, and when?

VAULT is an open proposal for public review. It is not a certification, a recognized standard, a completed cryptographic protocol, or legal, security or privacy advice. No product is certified, endorsed or assessed by this document.